Phase 1 API Delivery Report

MBHONI admin service

Phase 1 delivers a tenant-scoped, read-only JSON API with API-key authentication. This report records the problems addressed, the features delivered, and the validation results, with the subsequent billing migration fix identified separately.

Problems addressed

Problem	Phase 1 fix
API and UI authentication needed separation	Added a higher-priority security chain for /api/v1/** and the new documentation paths.
Existing filters could interfere or create sessions	Added narrowly scoped filter exclusions and stateless API authentication.
Key permissions did not define API scopes	Added centralized permission-to-scope mapping. Unmapped permissions grant no API access.
Tenant context could leak between requests	Set context from the authenticated key and clear it in a finally block.
Record IDs could allow cross-tenant requests	Used tenant-scoped lookups and added cross-tenant regression tests.
GET operations could create default rows	Used read-only repository calls and DTO defaults without creating records.
Authentication failures could redirect to login	Added RFC 7807 JSON errors, including HTTP 401 for missing credentials.
Documentation could expose unintended routes	Restricted documentation to /api/docs and /api/openapi.json.
Module incremental retrieval needed consistent timestamps	Used the latest timestamp across related records and documented timestamp limitations.
New security behavior could disrupt existing endpoints	Added legacy-route parity, CSRF, session, and Stripe signature-verification regression tests.

Features delivered

The API exposes tenant data through explicit DTOs and checks API scopes before granting access.

Feature	Endpoint or behavior
Authenticated key identity	GET /api/v1/users/me
Tenant-scoped user profile	GET /api/v1/users/{id}
User permission check	POST /api/v1/access/check Read-only despite using POST.
Tenant profile and settings	GET /api/v1/tenant
Tenant branding	GET /api/v1/tenant/branding
Tenant quota information	GET /api/v1/tenant/quotas
Paginated modules and incremental filtering	GET /api/v1/tenant/modules Supports updatedSince.
Module entitlement lookup	GET /api/v1/tenant/entitlements/{module}
API documentation and OpenAPI specification	/api/docs /api/openapi.json
Consistent response contracts	Explicit DTOs, response envelopes, pagination metadata, and structured errors.
Integration guide	Scope mapping, timestamp behavior, limitations, and prerequisites for future JWT support.

Validation and scope

Item	Result or boundary
Phase 1 test suite	222 tests; zero failures or errors; one existing opt-in test skipped.
Authentication supported	API keys. JWT support is documented for future implementation and is not included in the code.
Database migrations	No database migrations were introduced by Phase 1.
Legacy-route compatibility	Regression coverage checks existing route behavior, CSRF requirements, and handling of X-API-Key headers.
Stateless behavior	Regression coverage checks that API requests do not create sessions or emit session cookies.
Stripe webhook compatibility	Regression coverage exercises the existing signature-verification path.

Subsequent billing startup fix

This fix was completed after Phase 1 and is separate from the API delivery.

Item	Detail
Problem	Billing migration V12 attempted to add invoices.currency, which migration V1 already creates. MySQL error 1060 blocked startup.
Fix	Removed the duplicate column addition from V12, preserving the existing currency column and data.
Regression validation	A MySQL regression test reproduced the original failure and passed after the fix. It checked existing currency values and amounts, added fields, Stripe invoice ID uniqueness, and Flyway rerun behavior.
Breaking change or backfill	Neither is required for the reported failure.
Remaining verification	Full application startup against the application database remains unverified.